System Vulnerability Assessment

Course code: CYS 330

Course Lecturer: Paul M. Mutunda - Tec Dip., Ad. Dip CS., COMPTIA A+ Cert., BICT, M. Sc.

Vulnerability Rating scales

- The Common Vulnerability Scoring System (CVSS) is a standardized framework used to assess the severity of software vulnerabilities, providing a numerical score ranging from 0 to 10.
- This score helps organisations prioritize their responses to vulnerabilities based on their potential impact.

CVSS Score Rating

1. **Low (0.0 – 3.9): Minimum risk**, often requiring specific conditions for exploitation.
2. **Medium (4.0 – 6.9): Moderate risk:** Vulnerabilities are more common and easier to exploit but typically do not lead to severe consequences
3. **High (7.0 – 8.9) High Risk:** Significantly threats that may allow unauthorised access or control over systems.
4. **Critical (9.0 – 10.0) Over alert:** Extremely dangerous vulnerabilities that can lead to widespread exploitation and sever impacts, such as data loss or system takeover or even system downtime.

Metric Groups

- CVSS consists of three main metric groups as listed below;

1. **Base Metrics:** This metrics in the CVSS represents the intrinsic characteristics of a vulnerabilities that are constant over time and across user environments. They are composed of two (2) sets of metrics: Allows you to access data from your data source.

(a) Exploitability Metrics : A type of Base Metrics which reflects the ease and technical means by which the vulnerability can be exploited. They represent characteristics of vulnerable components:

(i) Attack vector (AV) which assess the conditions necessary for an attacker to exploit the vulnerability.

(ii) Attack Complexity (AC) which evaluates the conditions beyond the attacker's control that must exist for the attack to succeed. T

(iii) Privileges Required (PR) which measures the level of privileges an attacker must poses before successfully exploiting the vulnerability.

(iv) User Interaction (UI) which determines whether the vulnerability can be exploited solely by an attacker or if a user must participate in some manner.

Metric Groups cont.

(b) **Impact Metrics:** These matrices reflect the direct consequences of a successful exploit, representing the impact on the impacted component.

(i) Confidentiality Impact (C): Measures the impact on confidentiality of a successful exploited vulnerability.

(ii) Integrity impact (I): Measures the impact on integrity of a successfully exploited vulnerability

(iii) Availability Impact (A): Measures the impact on vulnerability of a successfully exploited vulnerability.

- The Base Metrics are used to calculate the Base Score which ranges from 0 to 10.
- This score reflects the severity of the vulnerability according to its intrinsic characteristics, assuming the reasonable worst – case impact across different deployed environments.

Metric Groups cont.

2. **Temporal Metrics**

- CVSS Temporal Metrics assess the time – dependent aspects of a vulnerability's exploitability, reflecting how the risk associated with a vulnerability can change over time. In other words, they change over the lifetime of a vulnerability.
- These metrics help security professionals understand the current exploitability of a vulnerability beyond its inherent characteristics
- The following are some key components about Temporal Metrics:

(i) **Exploit Code Maturity:** Evaluates the availability and sophistication of exploit code. Higher maturity indicates easier exploitation

(ii) **Remediation Level:** Assesses the availability of official patches or workarounds. A higher level suggest more effective remediation options are available.

(iii) **Report Confidence:** Measures the reliability of the information regarding the vulnerability. Higher confidence indicates that the vulnerability is well – documented and acknowledged by the vendor.

Metric Groups cont.

- These metrics do not generate specific scores but provide a framework for evaluating a vulnerability’s overall severity in the context of its current state and available mitigation.

Metric Groups cont.

3. **Environmental Metrics**

- CVSS Environmental Metrics allow organisations to customize the severity score of a vulnerability based on specific contextual factors relevant to their environment.
- These metrics serve as modifiers to the Base and Temporal metrics helping to reflect the actual impact of a vulnerability within a particular organisational context.
- The following are some key points to take not of on Environmental Metrics;

(i) **Modified Base Metrics:** Orgnaisation's can adjust the Base metrics based on existing security controls or mitigations. For instance, if a server computer is air – gapped or protected by a robust firewall, the likelihood of exploitation may be reduced, leading to a lower score.

Metric Groups cont.

(ii) **Security Requirement:**

- This component assesses the criticality of the asset in question, measured against the **Confidentiality, Integrity, Availability (CIA)** triad. Organisations can assign values to indicate the importance of each aspect.
- **Not Defined (X):** No impact on the overall Environmental score
- **High (H):** Catastrophic impact if compromised.
- **Medium (M):** Serious adverse impact if compromised.
- **Low (L):** Limited or isolated impact if compromised.
- By incorporating Environmental Metrics, organisations can better prioritize vulnerabilities based on their unique risk profiles and operational contexts, leading to more effective vulnerability management strategies.

Exam questions

1. Outline the differences between base metrics and Temporal metrics [2]
2. Explain in detail, the importance of Environmental metrics. [2]
3. Give one reason why an IT department use air gapping [1]
4. Outline the four (4) CVSS scoring rates and explain in detail, measures that you would take based on the score outlined [8]